

Tema 5

Gestión de Activos. Análisis de Riesgos

Introducción	2
Marco de gobierno, Gestión de riesgos y cumplimiento.....	3
Dimensiones de la seguridad.....	3
Análisis de riesgos	4
Clases de Activo	5
Gestión de activos según ISO 27001.....	6
Gestión Reactiva vs Proactiva	8
Vocabulario de la Gestión del Riesgo.....	8
Tipología de Análisis de Riesgos	11
Análisis Coste-Beneficio - ROI	11
Metodologías de análisis de riesgos.....	12
MAGERIT v3.0.....	13

Introducción

Nos encontramos en un mundo en el que cada vez se depende más de las tecnologías de la información y comunicaciones (TIC), las tecnologías cada vez ofrecen más posibilidades, pero también riesgos que deben gestionarse debidamente con medidas de seguridad.

El **riesgo** se podría definir como la **combinación de la probabilidad de un suceso y sus consecuencias**.

No hay empresa libre de riesgos, todas tienen un potencial de sucesos y consecuencias que pueden llevar a cabo oportunidades para conseguir beneficio o amenazas para el éxito.

Por lo que el **CSAE** (Consejo Superior de Administración

Electrónica) ha elaborado y **promueve Magerit** (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información).

A lo largo de esta presentación mostraremos Pilar, una aplicación desarrollada por el CCN que nos ayudará en gran medida a gestionar los diferentes riesgos.

Además, es **importante no olvidar** nunca **que el análisis de riesgos es una actividad de despacho** y que es **imprescindible ver** qué ocurre en la **práctica** y **actuar en consecuencia**, tanto reaccionando diligentemente a los incidentes, como **mejorando continuamente** nuestro conocimiento del sistema y de su entorno para mejorar el análisis y ajustarlo a la experiencia.

A continuación veremos los diferentes activos y sus correspondientes amenazas para poder valorar el riesgo correctamente.

¿Qué es lo que debo hacer?

Tienes que proteger tus datos, los de tus clientes, tus transacciones, tu página web, tus servidores, tus instalaciones, etc. Debemos priorizar las decisiones para invertir en garantizar la confidencialidad, integridad y disponibilidad de la información.

Marco de gobierno, Gestión de riesgos y cumplimiento.

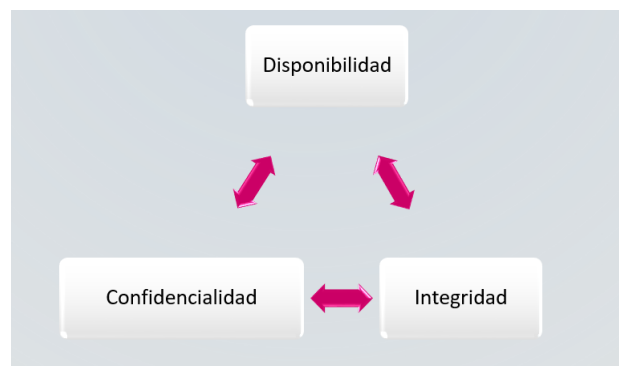
El conocimiento de los riesgos permite calibrar la confianza en que los sistemas desempeñarán su función como la Dirección espera, habilitando un marco equilibrado de Gobierno, Gestión de Riesgos y Cumplimiento.



Dimensiones de la seguridad

El objetivo a proteger es la misión de la Organización, teniendo en cuenta las diferentes dimensiones de la seguridad.

A continuación, se explicará cada dimensión de seguridad.



Disponibilidad

Disponibilidad o disposición de los servicios a ser usados cuando sea necesario. La carencia de disponibilidad supone una interrupción del servicio. La disponibilidad afecta directamente a la productividad de las organizaciones.

Integridad

Integridad o mantenimiento de las características de completitud y corrección de los datos. Contra la integridad, la información puede aparecer manipulada, corrupta o incompleta. La integridad afecta directamente al correcto desempeño de las funciones de una Organización.

Confidencialidad

Confidencialidad o que la información llegue solamente a las personas autorizadas. Contra la confidencialidad o secreto pueden darse fugas y filtraciones de información, así como accesos no autorizados. La confidencialidad es una propiedad de difícil recuperación, pudiendo minar la confianza de los demás en la organización que no es diligente en el mantenimiento del secreto, y pudiendo suponer el incumplimiento de leyes y compromisos contractuales relativos a la custodia de los datos.

Análisis de riesgos

El análisis de riesgos proporciona un modelo del sistema en términos de activos, amenazas y salvaguardas, y es la piedra angular para controlar todas las actividades con fundamento. La fase de tratamiento estructura las acciones que se acometen en materia de seguridad para satisfacer las necesidades detectadas por el análisis. El análisis de riesgos considera los siguientes elementos:

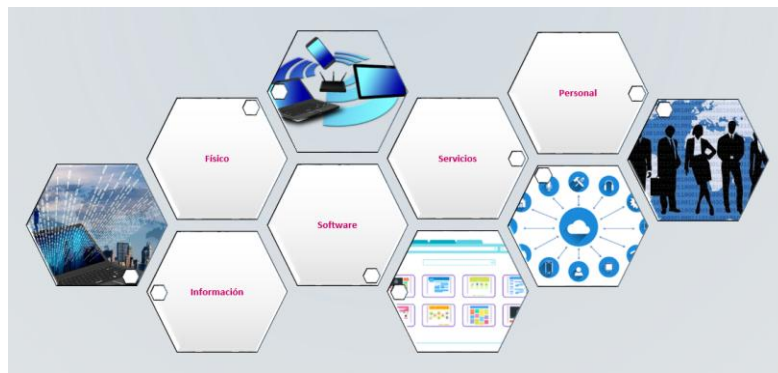
- ☐ **Activo:** Cualquier información o elemento relacionado con el tratamiento de la seguridad de la información (sistemas, soportes, edificios..) que tengan valor para la organización. [ISO/IEC 27000]
- ☐ **Amenaza:** Causa potencial de un incidente no deseado, que puede causar daño a un sistema u organización. [ISO/IEC 27000]
- ☐ **Vulnerabilidad:** Debilidad de un activo o control que puede ser explotada por una o mas amenazas. [ISO/IEC 27000]
- ☐ **Impacto :** Coste para la empresa de un incidente, que puede o no ser medido en términos estrictamente financieros [ISO/IEC 27000]

Clases de Activo

ACTIVO es cualquier cosa que tiene valor para una organización. [ISO/IEC 27000:2009]

Existen muchas clases de activos, incluyendo entre otras:

- Información
- Software
- Físico (o tangible)
- Servicios
- Personal
- Intangibles



Definición de Información

INFORMACIÓN → Definición: Conocimiento o Datos que tienen valor para una organización [ISO/IEC 27000:2009]

Ejemplos de Información:

- Bases de datos y ficheros de datos (su contenido).
- Contratos y Acuerdos.
- Información de desarrollo e investigación.
- Documentación del sistema, Manuales de usuario, Materiales para la formación, etc.
- Procedimientos operativos e información de soporte, Instrucciones técnicas, Manuales de Operación, etc.
- Planes de Continuidad de Negocio, procedimientos de "roll-back", acuerdos de continuidad, etc.
- Pistas de auditoría, información archivada, etc.

Gestión de activos según ISO 27001

[7.1] En base a los requisitos exigidos por la norma ISO 27001 la gestión de activos debería incluir los siguientes puntos:

- Inventarios de Activos
- Propiedad (Responsabilidad) de los activos
- Guía de uso aceptable de los activos

Además, también especifica que la información debería cumplir los siguientes requisitos:

- Clasificarse en función de los requisitos legales y su sensibilidad.
- Etiquetarse y manejarse según su clasificación.

Inventario de activos

Se debe identificar todos los activos, así como crear y mantener actualizado un inventario de activos. Debe contener:

- Propietario del activo
- Clasificación de la información
- Descripción de activo
- Información necesaria para recuperarse de un desastre

Propiedad de activos e información

- Toda la información y los activos deben tener asignado un propietario.
- **Propietario (ISO 27002):** Persona o entidad a la que formalmente se asigna la responsabilidad de gestión de un activo.
- El termino propietario no implica propiedad o derecho sobre el activo.
- El propietario debe revisar periódicamente los activos bajo su responsabilidad cumplen con todos los requisitos.

Uso aceptable de los activos

- Deben identificarse, documentarse e implementarse reglas para un uso aceptable de los activos asociados con información de negocio.
- Se debe regular el buen uso de los activos, por ejemplo en:
 - Reglas para el uso del correo electrónico e Internet.
 - Guías para el uso de dispositivos móviles.
 - Reglas para la aceptación y devolución de activos.

Clasificación de la Información

[7.2] La información deberá ser clasificada en función de su valor, sensibilidad y criticidad para la organización.

Consejo: Simplificar los niveles de Clasificación de manera que sea viable la misma.

Ejemplo de clasificación:

- **Confidencial:** Esta información debe ser únicamente compartida entre personal seleccionado que necesite ser conocedor de la misma.
- **Restringida:** normalmente es de uso interno, pero puede ser compartida entre los usuarios (contratados y subcontratados que hayan firmado acuerdo de confidencialidad), y puede ser compartida entre las partes interesadas (clientes, proveedores, etc.) con algún tipo de contrato o acuerdo marco de colaboración.
- **Pública:** Puede ser accedida por cualquier persona

Ejemplos:

- Restringida: documentos operativos, sgsi
- Confidencial: documentación de gerencia, nóminas, código fuente ...

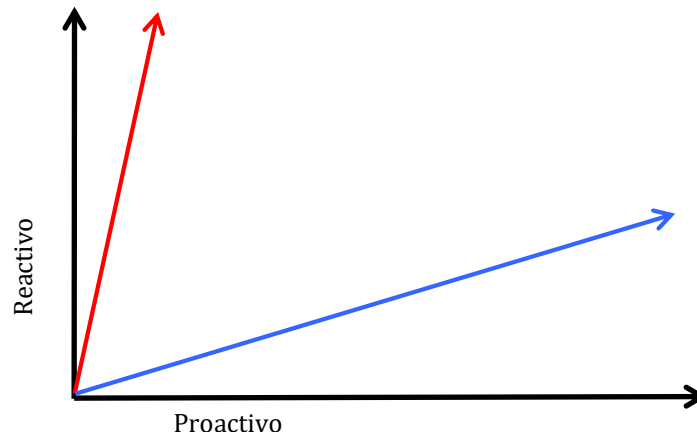
Etiquetado y manejo de la Información

- Deben desarrollarse e implementarse procedimientos para el etiquetado de la información en función del esquema de clasificación adoptado.
- Se debe etiquetar tanto para activos físicos como electrónicos.

Consejo: Implementar el etiquetado electrónico puede incluir métodos como mostrar mensajes y alertas al usuario, anexar metadatos, etc.

Gestión Reactiva vs Proactiva

- **Aproximación Reactiva:** Identificar vulnerabilidades y reaccionar "parcheando" las mismas de manera continua.
- **Aproximación Proactiva:** Identificar riesgos potenciales y reaccionar a través de la Gestión del Riesgo, reduciéndolos disminuyendo la probabilidad de incidentes futuros.

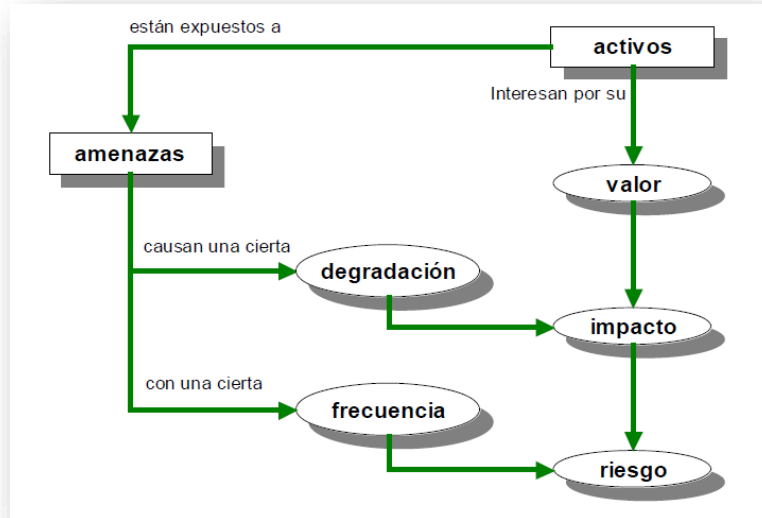


*La línea roja representa un enfoque reactivo de una organización que no ha formalizado sus procesos de seguridad. La línea azul representa una organización que ha implantado la norma ISO 27001 con cierta madurez. **A más madurez más acercamiento al enfoque proactivo.***

Vocabulario de la Gestión del Riesgo

- ❑ **Riesgo Potencial:** Posibilidad de que se produzca un impacto en un activo.
- ❑ **Salvaguarda:** Cualquier procedimiento, control o acción que reduzca el riesgo sobre un determinado activo o grupo de activos.
- ❑ **Riesgo Residual:** Riesgo remanente tras haber aplicado una salvaguarda sobre un activo o grupo de activos.
 - **Riesgo inherente:** ninguna medida de seguridad se haya establecido para paliar la degradación o la frecuencia de ocurrencia de la amenaza/vulnerabilidad.
 - **Riesgo inherente:** **valor acumulado del activo x degradación x frecuencia**

- ❑ **Análisis de riesgos:** Proceso que incluye la identificación de los riesgos, su clasificación por orden de magnitud y la determinación de aquellas áreas que requieren la aplicación de salvaguardas.



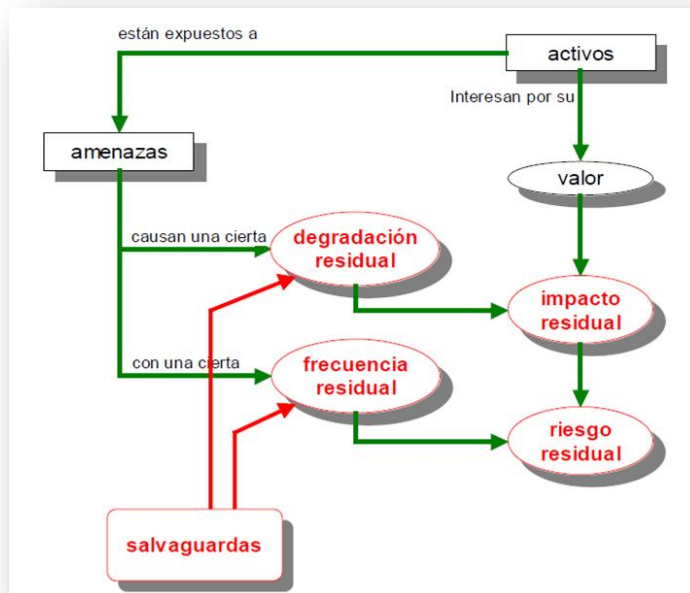
- ❑ **Tratamiento del Riesgo:** Proceso de selección e implantación de medidas para disminuir el nivel de riesgo. Suele implementarse a través de un **Plan del Tratamiento del Riesgo (PTR)**.

- **Operaciones de tratamiento del riesgo:**

Una vez que **hemos analizado y valorado** correctamente los **riesgos** **debemos decidir** cómo tratar estos. Disponemos de diferentes **posibilidades** a la hora de decidir tales como:

- **Eliminación:** en un sistema podemos eliminar varias cosas, siempre que no afecten a la esencia de la organización. Es extremadamente raro que podamos prescindir de la información los servicios esenciales, por lo que cambiar estos activos supone reorientar la misión de la organización. Por ello, encontramos mejores opciones, podemos **eliminar ciertos activos u emplear otros en su lugar**, por ejemplo cambiar el sistema operativo o reordenar la arquitectura del sistema segregando redes o desdoblado equipos.
 - **Mitigación:** La mitigación del riesgo consiste en **reducir la degradación** causada por una amenaza o **reducir la probabilidad** de que una amenaza se materialice.

- **Transferir:** la transferencia puede ser parcial o total y encontramos dos formas de compartir el riesgo:
 - **Cualitativamente:** se **comparte** por medio de la **externalización** de **componentes** del sistema, de forma **que se reparten responsabilidades**: unas técnicas para que el que opera el componente técnico; y otras legales según el acuerdo que se establezca de prestación del servicio.
 - **Cuantitativamente:** se **comparte por medio de** la contratación de **seguros**, de forma que el tomador reduce el impacto de las posibles amenazas y el asegurador corre con las consecuencias.
 - **Asumir :** en el caso de que se acepte el riesgo, la organización puede **reservar fondos para el caso de que el riesgo se concrete** y haya que responder a sus consecuencias. A veces se habla de **fondos de contingencia** y también puede ser parte de los **contratos de aseguramiento**.
- ❑ **Gestión del Riesgo:** Proceso global que incluye un análisis de riesgos, un tratamiento del riesgo a través de la selección de controles aplicables al resultado del mismo en función del análisis coste-beneficio del negocio y el ciclo de mejora continua aplicando a dicha gestión.



Tipología de Análisis de Riesgos

Existen básicamente dos tipologías o aproximaciones al Análisis de Riesgos:

- **Análisis Cuantitativo:** Trata de cuantificar numéricamente el riesgo asociado a cada activo o grupo de activos.
- **Análisis Cualitativo:** El riesgo asociado a cada activo o grupo de activos se valora en una escala de valores predefinida.

Otra aproximación es la **Mixta**, en la cual se hace una valoración cualitativa para los riesgos asociados a todos los activos y se realiza además una aproximación cuantitativa para los activos que requieran una mayor inversión en salvaguardas.

Análisis Coste-Beneficio - ROI

La gestión de riesgos tiene como misión proteger al **Negocio** de la organización de manera proactiva y desde un punto de vista que maximice el **Retorno de Inversión (ROI)**.

ROI (Return Over Investment): Representa el retorno asociado a una inversión, bien porque produce beneficios o elimina costes futuros.

$$\text{ROI (\%)} = [(G - I) / I] * 100 = (B / I) * 100$$

donde:

- G es la Ganancia o Reducción de Costes asociada a la Inversión
- I es la Inversión Inicial
- B es el Beneficio, es decir $B = (G - I)$

Metodologías de análisis de riesgos

Existen diversas metodologías de Análisis de Riesgo, citamos algunas relevantes entre ellas:

- **MAGERIT v3.0**
- **OCTAVE**
- **CRAMM**

MAGERIT v3.0

Es la metodología de análisis y gestión de riesgos elaborada por el Consejo Superior de Administración Electrónica, que estima que la gestión de los riesgos es una piedra angular en las guías de buen gobierno. El nombre de MAGERIT viene de Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información de las administraciones públicas. No obstante también proporciona un marco valido para el desarrollo de análisis de riesgos en entidades privadas.

Creada por el CSAE del MAP en 1997. Es una metodología pública y se puede acceder a las guías de manera gratuita. Actualmente la versión vigente es la 3.0, que consta de tres libros:

- Método
- Catálogo de Elementos
- Guía de Técnicas

MAGERIT es por tanto una metodología que incluye varias guías y que puede implementarse con o sin herramientas SW.

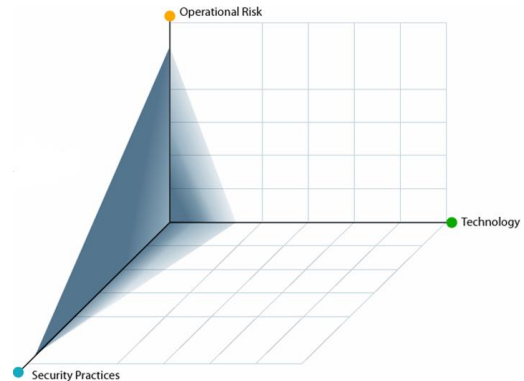
OCTAVE

Es una metodología de análisis de riesgos desarrollada por la Universidad Carnegie Mellon en el año 2001, y su acrónimo significa «**Operationally Critical Threat, Asset and Vulnerability Evaluation**». Esta metodología estudia los riesgos en base a tres principios: Confidencialidad, Integridad y Disponibilidad. Se emplea por distintas agencias gubernamentales como el Departamento de defensa de Estados Unidos.

Basada en seminarios que implican a equipos interdisciplinarios de trabajo desde el nivel estratégico de alta dirección, pasando por el nivel táctico y operativo.

Se basa en un triple enfoque abarcando:

- Riesgo Operativo
- Buenas Prácticas de Seguridad
- Tecnología



CRAMM

Se trata de la metodología de análisis de riesgos desarrollado por la Agencia Central de Comunicación y Telecomunicación del gobierno británico. El significado del acrónimo proviene de **CCTA Risk Analysis and Management Method**. Al igual que MAGERIT, tiene un alto calado en administración pública británica, pero también en empresas e instituciones de gran tamaño.

Es una metodología propietaria y está orientada a herramienta (un programa SW). Consta de tres Fases:

- **Fase I.** Establecer Objetivos de Seguridad
- **Fase II.** Análisis de Riesgo
- **Fase III.** Identificar y seleccionar salvaguardas

MAGERIT v3.0

Paso 1 – Identificación de activos

Se deberán identificar los activos que soportan los servicios de la organización, junto al propietario de cada uno.

Un **activo** es un **componente o funcionalidad** de un sistema de información **susceptible de ser atacado** deliberada o accidentalmente con consecuencias para la organización. Incluye: información, datos, servicios, aplicaciones (software), equipos (hardware), comunicaciones, recursos administrativos, recursos físicos y recursos humanos.

En un sistema de información **encontraremos dos cosas de vital importancia, la información que se maneja y los servicios que presta**, cosa que marcará los requisitos de seguridad para todos los demás componentes del sistema.

Se establece la siguiente división por defecto a la hora de realizar el inventario de activos, no obstante, esta división puede variar en base al criterio de la entidad:

- | | |
|--|---|
| ☐ [B] Capa de negocio – Catálogo de servicios | ☐ [E] Equipos |
| ☐ [D] Datos | ☐ [EV] Equipos virtuales |
| ☐ [CO] Contexto de la Organización | ☐ [COM] Comunicaciones |
| ☐ [SI] Servicios internos | ☐ [AUX] Elementos auxiliares |
| ☐ [SS] Servicios Subcontratados | ☐ [P] Personal |
| ☐ [SW] Aplicaciones | ☐ [L] Instalaciones |

Subordinados a dicha existencia, identificamos otros activos relevantes:

- **Datos** que materializan la información.
- **Servicios** auxiliares que se necesitan para poder organizar el sistema.
- **Las aplicaciones informáticas** que permiten manejar los datos.
- **Los equipos informáticos** que permiten hospedar datos, aplicaciones y servicios.
- **Los soportes de información** que son dispositivos de almacenamiento de datos.
- **El equipamiento auxiliar** que complementa el material informático.
- **Las redes de comunicaciones** que permiten intercambiar datos.
- **Las instalaciones** que acogen equipos informáticos y de comunicaciones.
- **Las personas** que explotan u operan todos los elementos anteriormente citados.

También cabe destacar que no todos los activos son de la misma especie, dependiendo del tipo de activo, las amenazas y las salvaguardas son diferentes.

Paso 2 – Dependencias

Se entiende por "**dependencias entre activos**" como la medida en que un activo superior se vería afectado por un incidente de seguridad en un activo inferior.

Se puede estructurar el conjunto de activos en capas, donde las capas superiores dependen de las inferiores:

- **Capa 1** Entorno
- **Capa 2** Sistemas de información
- **Capa 3** Información
- **Capa 4** Funciones de la organización
- **Capa 5** (No siempre se considera)

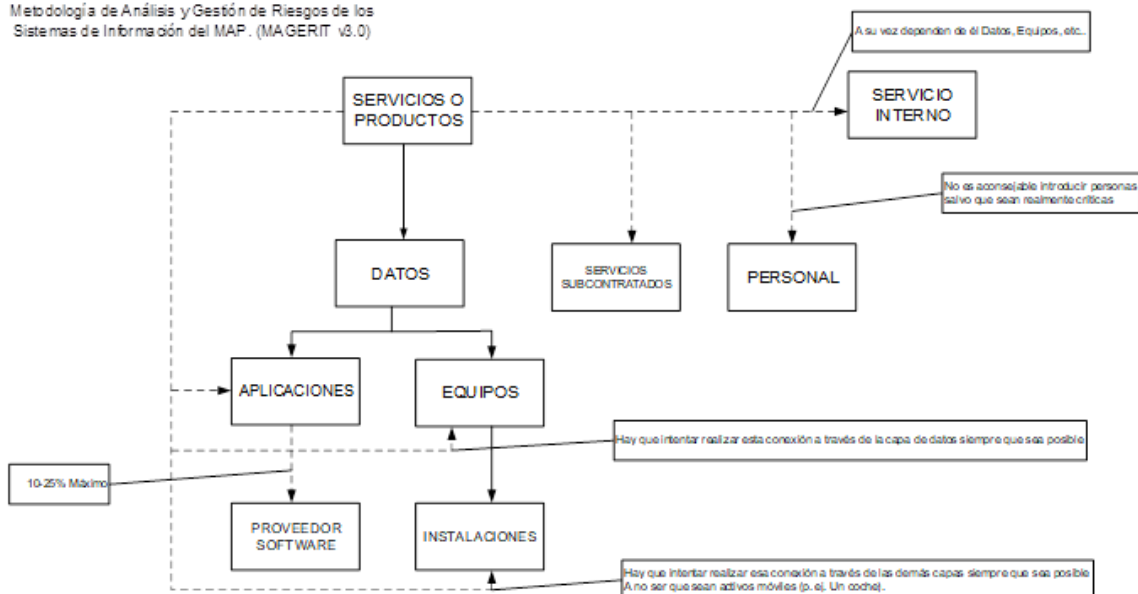
Se realiza un estudio de dependencias entre los activos, de modo que cada nivel tiene dependencias respecto a los niveles inferiores, comenzando por los servicios (Capa de Negocio) y si procede por el nivel de Información/Datos.

Los **activos esenciales** son la **información** y los **servicios** prestados; pero **estos activos dependen de otros activos** más prosaicos como pueden ser los equipos, las comunicaciones, las instalaciones y las personas que trabajan con ellos.

De esta forma, **los activos forman árboles** o grafos **de dependencia** donde la seguridad de **los activos superiores depende de los activos inferiores**. Estas estructuras reflejan de arriba hacia abajo las dependencias, mientras que de abajo hacia arriba la propagación del daño en caso de materializarse las amenazas.

En este caso, los datos dependerían de las aplicaciones y en caso de que estas fallen no podríamos acceder a estos o ofrecer los servicios o productos en cuestión.

Metodología de Análisis y Gestión de Riesgos de los
Sistemas de Información del MAP. (MAGERIT v8.0)



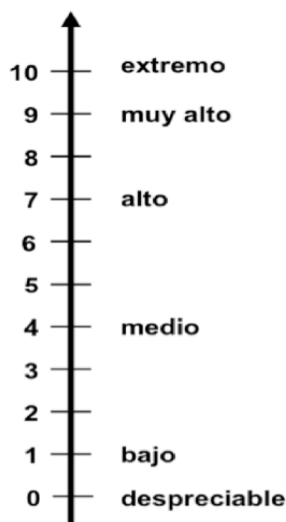
Grados. Encontramos importantes variaciones en el grado de dependencia de los activos, podemos encontrar **desde activos independientes** hasta activos con **dependencia absoluta**.

Coeficiente entre 0% (activos independientes) y 100% (activos con dependencia absoluta):

- **100% dependencia absoluta.**
- **80% altamente dependiente**, cualquier impacto se propaga al activo y afecta de forma crítica, no pudiendo prestar el servicio.
- **50% dependencia de igual grado de varios elementos** que se complementan en la prestación de un servicio.
- **30%** cuando la **degradación parcial** y **no afecta a la prestación del servicio**.
- **10%** para la **dependencia sobre un elemento redundado**.
- **0% activos independientes.**

Paso 3 – Valoración de Activos

La **valoración** del activo se basa en su **criticidad**. Dicha criticidad está valorada de 0 a 10 siendo su significado el siguiente:



valor		criterio
10	extremo	daño extremadamente grave
9	muy alto	daño muy grave
6-8	alto	daño grave
3-5	medio	daño importante
1-2	bajo	daño menor
0	despreciable	irrelevante a efectos prácticos

La valoración asignada tendrá que asociarse a la dimensión (Disponibilidad, Integridad o Confidencialidad) que relacione al activo con el negocio de la empresa.

Dentro de un **activo** podemos identificar diferentes **dimensiones**:

- **Confidencialidad:** es el **daño** que causaría que **una persona que no deba conocer un dato lo conociera**, esta **valoración** es **típica** de los **datos**.
- **Integridad:** es el **perjuicio que causaría que un activo estuviera dañado o corrupto**, es una valoración **típica de los datos**, que **pueden estar manipulados** totalmente, ser parcialmente falsos o incluso faltando datos.
- **Disponibilidad:** es el **perjuicio que causaría no tener un activo o no poder utilizarlo**, es una valoración típica en los servicios.
- **Autenticidad:** ¿qué **perjuicio causaría no saber quien hace o ha hecho cada cosa**? Esta **valoración es típica de servicios** (autenticidad del usuario) **y de los datos** (autenticidad de quien accede a los datos para escribir, o simplemente, consultar).
- **Trazabilidad:** ¿qué **daño causaría no saber a quién se le presta tal servicio**? Es decir, ¿**quién hace qué y cuando**? También encontramos trazabilidad del acceso a los datos: ¿qué **daño causaría no saber quién accede a qué datos y qué hace con ellos**?

Los activos interesan debido a lo que **valen**, si no fuera así, deberíamos prescindir de ello.

La valoración de un activo se puede ver como la necesidad de proteger un activo, siendo cuanto más valioso, más necesitado de mayor nivel de **protección**.

El **valor puede ser propio, o acumulado**. Se dice **que los activos inferiores en un esquema de dependencias, acumulan el valor** de los activos que se apoyan en ellos.

El **valor nuclear** suele estar en la **información que el sistema maneja y los servicios que se prestan** (activos denominados **esenciales**), quedando **los demás activos subordinados a las necesidades de explotación y protección de lo esencial**.

Por otra parte, los sistemas de información explotan los datos para proporcionar servicios, internos a la Organización o destinados a terceros, apareciendo una serie de datos necesarios para prestar un servicio. Sin entrar en detalles técnicos de cómo se hacen las cosas, el conjunto de información y servicios esenciales permite caracterizar una organización. Las dependencias entre activos permiten relacionar los demás activos con datos y servicios.

Como se vio anteriormente, la valoración puede ser cuantitativa o cualitativa. Los criterios más importantes a respetar son la **Homogeneidad y Relatividad**.

Paso 4 – Identificación de Amenazas

Una vez identificados los activos y valorados correctamente pasaremos a determinar las amenazas que pueden afectar a cada activo.

Una **amenaza** es la **causa potencial de un incidente** que puede causar daños a un sistema de información o a una organización, es decir, las amenazas son “cosas que ocurren”. Y, de todo lo que puede ocurrir, interesa lo que puede pasarle a nuestros activos y causar un daño.

Relación de amenazas típicas según el capítulo 5 del libro “Catálogo”. Mostramos algunos ejemplos a continuación:

- [N] Desastres Naturales
- [I] De origen Industrial
- [E] Errores y fallos no intencionados
- [A] Ataques intencionados

Tipos de Amenazas

- **De origen natural:** hay incidentes naturales (**terremotos, inundaciones**) ante los que el sistema de información es **víctima pasiva**, pero de todas formas tendremos en cuenta lo que pueda suceder.
- **Del entorno (de origen industrial):** hay desastres industriales (**contaminación, fallos eléctricos**) ante los cuales el sistema de información es **víctima pasiva**; pero no por ser pasivos hay que permanecer indefensos
- **Defectos de las aplicaciones:** hay problemas que nacen directamente en el equipamiento propio **por defectos en su diseño o su implementación**, con **consecuencias potencialmente negativas sobre el sistema**. Frecuentemente se denominan vulnerabilidades técnicas o, simplemente, “vulnerabilidades”.
- **Causadas por las personas de forma accidental:** las personas con acceso al sistema de información pueden ser causa de **problemas no intencionados, típicamente por error o omisión**.
- **Causadas por las personas de forma deliberada:** las personas con acceso al sistema de información pueden ser causa de **problemas intencionados como ataques deliberados; bien con el ánimo de beneficiarse indebidamente, bien con ánimo a causar daños y perjuicios a los legítimos propietarios**.

Por último, cabe destacar que no todas las amenazas afectan a todos los activos, por ejemplo una aplicación web no puede ser incendiada de la misma forma que un virus informático no puede infectar a una persona.

Una vez determinado que una amenaza puede perjudicar a un activo, hay que estimar en qué dimensión le afecta así como cuán vulnerable es el activo, en dos sentidos:

- **Degradación:** cuán perjudicado estimamos que resultará el activo
- **Frecuencia:** cada cuánto se estimamos que se materializará la amenaza.

La **degradación** mide el daño causado por un incidente en el supuesto de que ocurriera.

Degradación (%)	Estado del Activo
0%	Activo en perfecto estado
10%	Ligera degradación que no impide el funcionamiento
50%	Funcionamiento degradado, rendimiento bajo
90%	Prácticamente inservible
100%	El activo resulta totalmente inservible

Paso 5 – Valoración de Amenazas

Frecuencia: Indica cada cuanto estimamos que se materializará dicha amenaza. Cuyos posibles valores son:

Frecuencia	Valoración
Muy frecuente (100)	La amenaza aparece a diario
Frecuente (10)	La amenaza aparece mensualmente
Normal (1)	La amenaza aparece una vez al año
Poco frecuente (0,1)	La amenaza aparece cada varios años
Despreciable (0)	La amenaza nunca aparece

Ejemplo:

¿Qué dimensiones valorar?

En base a la gran cantidad de activos que podemos tener puede resultar complicado asignar riesgos a cada uno, es por ello que **MAGERIT ofrece un catálogo de diferentes amenazas**, los **activos a los que afectaría** la amenaza en cuestión y las **dimensiones a las que afectarían**, es decir, **integridad, disponibilidad y confidencialidad**.

5.1.1. [N.1] Fuego

[N.1] Fuego	
Tipos de activos: • [HW] equipos informáticos (hardware) • [Media] soportes de información • [AUX] equipamiento auxiliar • [L] instalaciones	Dimensiones: 1. [D] disponibilidad
Descripción: incendios: posibilidad de que el fuego acabe con recursos del sistema. Ver: EBIOS: 01- INCENDIO	

5.3.13. [E.20] Vulnerabilidades de los programas (software)

[E.20] Vulnerabilidades de los programas (software)	
Tipos de activos: • [SW] aplicaciones (software)	Dimensiones: 1. [I] integridad 2. [D] disponibilidad 3. [C] confidencialidad

Paso 6 – Valoración del Riesgo.

Determinación del Impacto

- **Impacto:** medida del daño sobre el activo derivado de la materialización de una amenaza.
- **Impacto acumulado:** Es el calculado sobre un activo teniendo en cuenta su valor acumulado (el propio mas el acumulado de los activos que dependen de él) y las amenazas a que está expuesto el propio activo.
- **Impacto repercutido:** Es el calculado sobre un activo teniendo en cuenta su valor propio y las amenazas a que están expuestos los activos de los que depende.

Determinación del Riesgo

- **Riesgo:** medida del daño probable sobre un sistema.
- **Riesgo acumulado:** Es el calculado sobre un activo teniendo en cuenta el impacto acumulado sobre un activo debido a una amenaza y la frecuencia de la amenaza.
- **Riesgo repercutido:** Es el calculado sobre un activo teniendo en cuenta el impacto repercutido sobre un activo debido a una amenaza y la frecuencia de la amenaza.



- ❑ **Impacto residual:** el impacto restante después del tratamiento del riesgo.

Las **salvaguardas reducen** la **degradación** causada por una amenaza en un activo, si evaluamos el impacto tomando en consideración el efecto mitigador de las salvaguardas, **el nuevo valor del impacto se llama residual**.

- ❑ **Riesgo residual:** riesgo remanente que existe después de que se hayan tomado las medidas de seguridad.

Las **salvaguardas reducen la probabilidad** de que una **amenaza** ocurra o la degradación derivada de su materialización. Cuando en la **evaluación del riesgo** utilizamos **los valores residuales para la probabilidad y la degradación** (es decir, los valores originales reducidos por la eficacia de la salvaguardas), entonces **el resultado es el riesgo residual**.

Una organización aceptará un riesgo residual, de que es el riesgo restante **después de desplegar sus salvaguardas**.

PROCESO DE GESTIÓN DE RIESGOS

En vista los impactos y riesgos a que está expuesto el sistema, hay que tomar **decisiones condicionadas por distintos factores**:

- La **gravedad** del **impacto** o del riesgo.
- Las **obligaciones** a las que por **ley** esté sometida la Organización.
- Las obligaciones a las que por **reglamentos sectoriales** esté sometida la Organización.
- Las obligaciones a las que por **contrato** esté sometida la Organización.

Además, pueden haber consideraciones adicionales sobre la capacidad de la Organización para aceptar ciertos **impactos de naturaleza intangible** tales como:

- **Imagen pública** de cara a la Sociedad (aspectos reputacionales).
- **Política interna.**
- **Relaciones con los proveedores:** capacidad de llegar a acuerdos ventajosos, capacidad de obtener trato prioritario, etc.
- **Relaciones con los clientes** o usuarios, tales como capacidad de retención, capacidad de incrementar la oferta, capacidad de diferenciarse frente a la competencia...
- **Nuevas oportunidades de negocio,** tales como formas de recuperar la inversión en seguridad.
- **Acceso a sellos o calificaciones** reconocidas de seguridad.

En base a las consideraciones anteriores, se puede determinar cuan significativo es el riesgo:

- **Crítico:** requiere atención urgente.
- **Grave:** requiere atención.
- **Apreciable:** puede ser objeto de estudio para su tratamiento.
- **Asumible:** no se van a tomar acciones.

CRITERIOS DE VALORACIÓN DEL RIESGO

A la hora de **valorar un riesgo** nos encontramos con una gran **incertidumbre**, por ello necesitamos saber el lugar al que podemos recurrir para establecer una mejor valoración:

- **Fuentes de información.**
- **Definición** de las **fuentes de riesgo.**
- **Metodología de evaluación.**
- Definición de **los criterios de riesgos asumibles.**
- **Valoración** de **cada uno de los riesgos.**



De acuerdo al criterio de valoración expuesto, se establece como nivel de riesgo aceptable un **riesgo menor que X**, según la escala de valoración empleada. Dichos riesgos suponen una situación a asumir por parte de la empresa, considerándose un **nivel de “riesgo residual bajo”**.

Seleccionar los **objetivos de control** y los **controles** del Anexo A de ISO 27001:2005 para el tratamiento del riesgo que cumplan con los requerimientos identificados en el proceso de evaluación del riesgo.

Aprobar por parte de la dirección tanto los **riesgos residuales** como la **implantación y uso del SGSI**. Hay que recordar que los riesgos de seguridad de la información son riesgos de negocio y sólo la Dirección puede tomar decisiones sobre su aceptación final en cada revisión y/o acciones de tratamiento. El riesgo residual es el que queda, aún después de haber aplicado controles (el "riesgo cero" no existe prácticamente en ningún caso).

- Definir el enfoque de evaluación de riesgos mediante una **metodología de evaluación del riesgo**.
 - El riesgo nunca es totalmente eliminable -ni sería rentable hacerlo-, por lo que es necesario definir una estrategia de aceptación de riesgo estableciendo criterios de aceptación del riesgo y especificar los niveles de riesgo aceptable.
 - Existen numerosas [metodologías](#) estandarizadas para la evaluación de riesgos y la organización puede optar por una de ellas.
 - Como documento de apoyo ISO 27005 sí profundiza en directrices sobre la materia.
- ❑ **Analizar y evaluar los riesgos**
- Evaluar el impacto en el negocio de un fallo de seguridad que suponga la pérdida de confidencialidad, integridad o disponibilidad de un activo de información;
 - Evaluar de forma realista la probabilidad de ocurrencia de un fallo de seguridad en relación a las amenazas, vulnerabilidades, impactos en los activos y los controles que ya estén implementados;
 - Estimar los niveles de riesgo.
 - Determinar, según los criterios de aceptación de riesgo previamente establecidos, si el riesgo es aceptable o necesita ser tratado.

❑ **Definir una declaración de aplicabilidad también llamada SOA (Statement of Applicability) que incluya:**

- Los objetivos de control y controles seleccionados y los motivos para su elección;
- Los objetivos de control y controles que actualmente ya están implantados;
- Los objetivos de control y controles del Anexo A excluidos y los motivos para su exclusión; este es un mecanismo que permite, además, detectar posibles omisiones involuntarias.

En relación a los controles de seguridad, el estándar ISO 27002 (antigua ISO 17799) proporciona una completa guía de implantación que contiene 133 controles, según 39 objetivos de control agrupados en 11 dominios. Esta norma es referenciada en ISO 27001:2013, en su segunda cláusula, en términos de "documento indispensable para la aplicación de este documento" y deja abierta la posibilidad de incluir controles adicionales en el caso de que la guía no contemplase todas las necesidades particulares.

❑ **Identificar y evaluar las distintas opciones de tratamiento de los riesgos para:**

- Aplicar controles adecuados (mitigación);
- Aceptar el riesgo (de forma consciente), siempre y cuando se siga cumpliendo con las políticas y criterios establecidos para la aceptación de los riesgos;
- Evitar el riesgo, p. ej., mediante el cese de las actividades que lo originan;
- Transferir el riesgo total o parcialmente a terceros, p. ej., compañías aseguradoras o proveedores de outsourcing.

Paso 7 – Tratamiento del Riesgo. Mitigar

Si atendemos a los **tipos de riesgos** y a la **mitigación** de los mismos, encontramos:

El Riesgo Inicial es el denominado **Riesgo Inherente**, el cual se calcula sin tener en cuenta los controles de seguridad implantados en el Sistema de Información.

Sobre el Riesgo Inherente debemos aplicar los **controles ya implantados** descubiertos durante el **Análisis Inicial**, y planificar aquellos que faltan por implantar.

Las acciones a llevar a cabo vendrán priorizadas por el riesgo a tratar y su situación con respecto al **Nivel de Riesgo Aceptable**, y formarán el **Plan de Tratamiento de Riesgos Riesgo** (PTR).

Una vez implantado el PTR, se deberá valorar la efectividad de los controles implantados y obtendremos el **Riesgo Residual**.

Controles de seguridad

En relación a los controles de seguridad, el estándar ISO 27002 (antigua ISO 17799) proporciona una completa guía de implantación que contiene [93 controles](#), según 4 objetivos de control agrupados en 14 dominios. Esta norma es referenciada en ISO 27001:2022, en su segunda cláusula, en términos de "documento indispensable para la aplicación de este documento" y deja abierta la posibilidad de incluir controles adicionales en el caso de que la guía no contemplase todas las necesidades particulares.

Es, en definitiva, un **resumen de las decisiones tomadas** en cuanto al **tratamiento del riesgo**.